AREM · UNIVERSIDAD DE LA SABANA · MÓDULO 09

Evaluación de Riesgos Arquitectónicos

Análisis técnico y estratégico para la defensa de sistemas

Objetivo: identificar, categorizar y mitigar riesgos en arquitecturas de sistemas mediante metodologías de análisis estructurado.

Profesor: Ing. César Augusto Vega Fernández

01 · OBJETIVO

Qué se lleva del módulo

Cuatro capacidades concretas, no cuatro temas

01

Distinguir

Separar un riesgo arquitectónico de un error de código, y explicar por qué el costo de corregirlos es distinto.

02

Identificar

Aplicar cuatro métodos sistemáticos de detección sobre la arquitectura de un cliente real.

03

Priorizar

Ubicar cada riesgo en una matriz de impacto y probabilidad, y justificar la ubicación.

04

Defender

Proponer una estrategia de mitigación por riesgo crítico y sostenerla ante preguntas.

ENTREGABLE · TALLER 9 · PASO 3

- Mínimo 5 riesgos identificados sobre las capas del sistema
- Cada uno ubicado en la matriz con su justificación
- Una estrategia de mitigación por riesgo crítico
- Defensa oral ante el comité evaluador

Falla conceptual frente a error de código

La distinción que define todo el módulo

EL ERROR DE CÓDIGO (BUG)

Naturaleza

Falla táctica en la implementación.

Detección

Aparece en pruebas o en QA rutinario.

Costo de corrección

Lineal y relativamente bajo.

Quién lo arregla

El desarrollador, en un sprint.

EL RIESGO ARQUITECTÓNICO

Naturaleza

Deficiencia fundamental en el diseño o la estructura.

Detección

Tarde, cuando el sistema ya está en producción.

Costo de corrección

Exponencial: exige reestructuración profunda.

Quién lo arregla

El equipo completo, en meses.

La consecuencia práctica: un bug se arregla; un riesgo arquitectónico se paga. Por eso se evalúan temprano y por eso este módulo existe.

De dónde vienen y en qué se convierten

Cuatro fuentes de riesgo, tres tipos de impacto

FUENTES DE RIESGO

Requisitos ambiguos

Interpretaciones erróneas que terminan en retrabajo y desvío de alcance.

Infraestructura deficiente

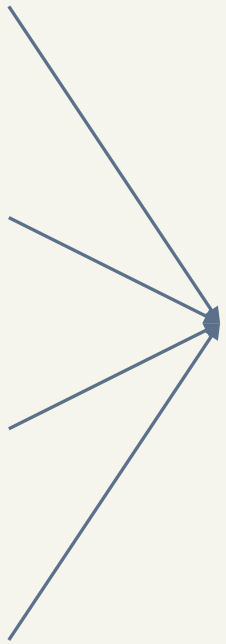
Base tecnológica débil que compromete estabilidad y rendimiento.

Equipos desalineados

Objetivos divergentes que reducen la eficiencia operativa.

Cambios frecuentes

Modificaciones constantes sin gestión, que generan inestabilidad.



TIPOS DE IMPACTO

Técnico

Deuda técnica alta, incompatibilidades, límites de rendimiento.

Seguridad

Vulnerabilidades críticas, exposición de datos, control de acceso deficiente.

Organizacional

Dependencia de proveedores, falta de soporte o de recursos internos.

Tres formas conocidas de fallar

Se reconocen por el síntoma, se diagnostican por la causa

SÍNTOMA

Microservicios desconectados

Servicios fragmentados con comunicación deficiente.

IMPACTO

Alta complejidad operativa; el mantenimiento y la trazabilidad se vuelven costosos.

SÍNTOMA

Monolito desproporcionado

Una sola unidad que concentra todo el sistema.

IMPACTO

Limita la escalabilidad, impide la adaptación ágil y frena los ciclos de despliegue.

SÍNTOMA

Sistema sin observabilidad

Ausencia de telemetría, métricas y trazas.

IMPACTO

Fallos silenciosos y resolución tardía de incidentes críticos.

Ninguno de los tres es un error de programación: los tres son decisiones estructurales que en su momento parecieron razonables.

Deuda cognitiva del código

El riesgo que apareció cuando la IA aceleró el ritmo de cambio

La brecha creciente entre lo que el sistema hace y lo que el equipo entiende de cómo y por qué funciona.

EL CICLO QUE SE REFUERZA

1	**La IA acelera el cambio**	Se produce más código en menos tiempo.
2	**El entendimiento se rezaga**	Nadie alcanza a reconstruir la intención de diseño.
3	**Se guía peor a la IA**	Sin entender el sistema no se anticipan los casos límite.
4	**El sistema se degrada más**	Y el ciclo vuelve a empezar, más rápido.

se retroalimenta

CONTRAMEDIDAS

- **Modelos vivos**

  Diagramas y ADR versionados junto al código, no en un Drive aparte.

- **Fitness functions**

  Reglas estructurales verificadas automáticamente en cada integración.

- **Cambios pequeños**

  Lotes acotados que un revisor humano alcance a entender.

- **Carga cognitiva del equipo**

  Medirla y tratarla como restricción de diseño, no como queja.

Cuatro métodos para encontrar lo que no se ve

Cada uno cubre un punto ciego de los otros tres

SISTEMA

Análisis de arquitectura

Examina el diseño estructural buscando vulnerabilidades, puntos únicos de fallo e ineficiencias.

¿Qué pasa si este componente deja de responder?

RED

Análisis de dependencias

Evalúa las interconexiones y revela cómo un fallo localizado se propaga en cascada.

¿Hasta dónde llega el daño si cae el proveedor de pagos?

HISTÓRICO

Listas de verificación

Usa experiencia previa y estándares de industria para una detección sistemática.

¿Qué le ha pasado antes a sistemas como este?

PERSONAS

Consulta a interesados

Recoge la perspectiva de usuarios finales y expertos mediante entrevistas.

¿Qué es lo que más miedo le da al equipo del cliente?

ATAM: el método formal de evaluación

Architecture Tradeoff Analysis Method · Software Engineering Institute

Es el método de referencia para evaluar una arquitectura antes de construirla. No busca errores: busca dónde la arquitectura pone en riesgo los atributos de calidad que el negocio necesita.

SECUENCIA SIMPLIFICADA

1
Drivers de negocio
Qué necesita el negocio del sistema

→

2
Arquitectura
Cómo está resuelto hoy

→

3
Árbol de utilidad
Atributos de calidad priorizados con escenarios medibles

→

4
Análisis
Confrontar enfoques contra escenarios

LO QUE PRODUCE

Riesgos
Decisiones que amenazan un atributo de calidad

No riesgos
Decisiones que resisten el análisis

Puntos de sensibilidad
Elementos donde un cambio mueve mucho un atributo

Puntos de compromiso
Elementos donde mejorar un atributo empeora otro

Los puntos de compromiso son los trade-offs del Módulo 8. ATAM es el método que los encuentra en vez de descubrirlos en producción.

Risk Storming sobre los diagramas C4

Simon Brown · el mismo autor del modelo C4 del Módulo 4

CÓMO SE HACE

1 Se imprime el diagrama

Se usa el C1 o el C2 del sistema; el mismo que ya construyeron en el Taller 3.

2 Cada quien marca en silencio

Sin hablar, cada participante pone un punto de color sobre los elementos que considera riesgosos: alto, medio o bajo.

3 Se consolida y se compara

Los elementos con más puntos, o donde el equipo no coincide, son los que importan.

4 Se prioriza y se mitiga

Solo entonces se discute: qué se hace con los elementos que quedaron marcados.

POR QUÉ EN SILENCIO

Si se discute antes de marcar, la primera opinión contagia al resto y desaparecen los puntos de vista minoritarios, que suelen ser los que detectan el riesgo real.

CONEXIÓN CON EL MÓDULO 4

Aquí se cierra el círculo: el diagrama de contenedores que hicieron para documentar el sistema es ahora la superficie sobre la que se analiza el riesgo. Ese es el motivo real para mantenerlo actualizado.

Matriz de impacto y probabilidad

Impacto en el eje vertical, probabilidad en el horizontal



REGLA

Un riesgo de alto impacto y baja probabilidad no se ignora: se le prepara un plan de contingencia. Lo que se acepta es lo que cae abajo a la izquierda.

El espectro de respuesta

De la acción más agresiva a la más pasiva

ACCIÓN AGRESIVA — ACCIÓN PASIVA

1. Eliminación

CAMBIO RADICAL

Erradica la fuente de la amenaza cambiando procesos o diseños fundamentales.

Retirar del sistema la integración que falla y resolver el caso por otra vía.

2. Reducción

CONTROLES ACTIVOS

Disminuye la probabilidad o el impacto mediante controles preventivos y detectivos.

Rate limiting, reintentos con backoff, circuit breakers.

3. Transferencia

DESPLAZAMIENTO

Traslada la consecuencia financiera u operativa a un tercero.

Contrato con SLA y penalidades, o póliza.

4. Aceptación

ASUNCIÓN INFORMADA

Se asume el riesgo cuando mitigar cuesta más que el daño esperado.

Aceptar una degradación menor en un componente secundario.

Aceptar es una decisión legítima, siempre que sea explícita y quede registrada. Aceptar sin decirlo es simplemente no haber mirado.

El modelo Bow-Tie

Dónde actúa cada control respecto al evento de riesgo

ANTES DEL EVENTO

Controles preventivos: evitan que el riesgo se materialice.

DESPUÉS DEL EVENTO

Controles reactivos: reducen el daño una vez ocurrió.



Aplicado a FarmApp: el evento es «la pasarela de pagos no responde». Preventivos: contrato con SLA y monitoreo del proveedor. Reactivos: reintento asíncrono y proveedor alterno. La mayoría de los equipos solo dibuja el lado izquierdo, y así el sistema queda sin plan para cuando el riesgo ocurra de todos modos.

Mapa de superficie de riesgo · FarmApp

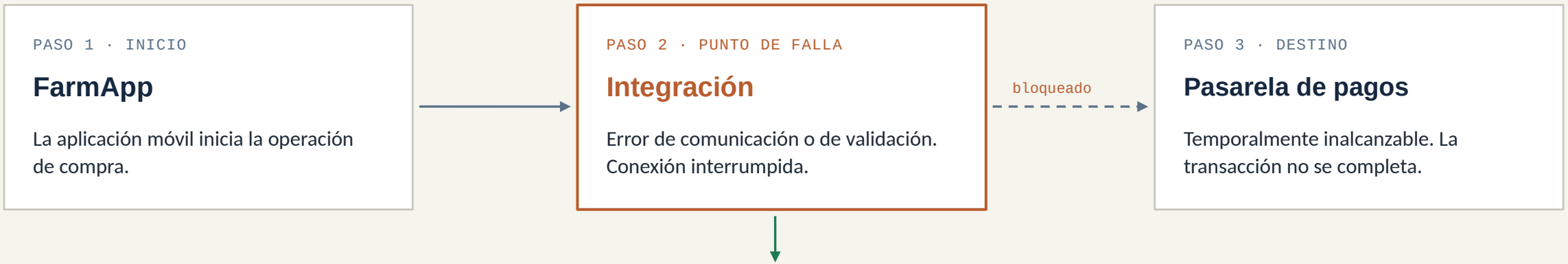
El riesgo se busca capa por capa, no de forma general

Capa 1 · Interfaz de usuario	**Riesgos:** Cross-Site Scripting (XSS), autenticación vulnerable, sesiones sin expiración.
Capa 2 · Lógica de negocio	**Riesgos:** Validación de datos insuficiente, reglas de negocio implementadas de forma inconsistente.
Capa 3 · Base de datos	**Riesgos:** Inyección SQL, cifrado ausente en reposo, respaldos sin verificar.
Capa 4 · Servicios externos	**Riesgos:** Fallos de latencia e integración con APIs de terceros no sustituibles.

Recorrer las capas evita el sesgo del equipo: casi siempre encuentran riesgos donde tienen más experiencia y ninguno donde tienen menos.

Zoom-in: fallo en la integración de pagos

Un riesgo concreto, de principio a fin



MITIGACIÓN ESTRUCTURAL · FALLBACK

Se implementa una ruta alternativa programada: la transacción se captura de forma asíncrona y se reintenta, o se redirige a un proveedor secundario. El usuario completa la compra aunque la pasarela principal esté caída.

Lo que hay que notar: el riesgo no está en FarmApp ni en la pasarela, sino en la relación entre las dos. Los riesgos arquitectónicos viven en las flechas del diagrama con más frecuencia que en las cajas.

El arsenal del arquitecto

Qué usar según el nivel de rigor que exija la decisión

SEGUIMIENTO OPERATIVO

Matriz en hoja de cálculo o Notion

Plataformas flexibles para registrar, priorizar y hacer seguimiento iterativo. Suficiente para el Taller 9.

```
Costo: gratuito · Curva: muy baja
```

ANÁLISIS CUANTITATIVO

Open FAIR

Marco abierto de The Open Group para expresar el riesgo en términos financieros y comparar alternativas con rigor.

```
Costo: estándar abierto · Curva: alta
```

ANÁLISIS COLABORATIVO

Risk Storming

Técnica de Simon Brown que se aplica sobre los diagramas C4 del sistema. Rápida, sin herramientas.

```
Costo: gratuito · Curva: muy baja
```

EVALUACIÓN FORMAL

ATAM

Método del SEI para evaluar la arquitectura contra los atributos de calidad del negocio.

```
Costo: gratuito · Curva: media-alta
```

Para el Taller 9 basta con la primera y la tercera. Las otras dos se nombran para que sepan que existen cuando trabajen en industria.

Preparación para el comité · Taller 9

45 minutos en equipo, sobre el sistema del cliente real

15 min

Identificación exhaustiva

Mapeen al menos 5 riesgos recorriendo las capas del sistema: interfaz, lógica, datos e integraciones. Usen Risk Storming sobre su diagrama de contenedores.

15 min

Evaluación rigurosa

Ubiquen cada riesgo en la matriz de impacto y probabilidad. Escriban la justificación: por qué ese cuadrante y no el vecino.

15 min

Defensa de la mitigación

Propongan una estrategia por riesgo crítico —eliminar, reducir, transferir o aceptar— y anticipen la pregunta que les va a hacer el comité.

LO QUE PREGUNTA EL COMITÉ

- ¿Por qué este riesgo y no otro?
- ¿Qué evidencia respalda esa probabilidad?
- ¿Cuánto cuesta mitigarlo y cuánto cuesta no hacerlo?
- ¿Qué riesgo decidieron aceptar y por qué?

PARA LLEVARSE

El manifiesto del riesgo arquitectónico

01 **Detección proactiva**

Descubrir dependencias ocultas a tiempo evita reestructuraciones exponenciales.

02 **Comunicación clara**

Traducir la complejidad técnica en impacto de negocio para alinear al cliente.

03 **Enfoque estructurado**

Usar métodos probados —ATAM, Risk Storming, Bow-Tie— reduce la omisión humana.

04 **Adaptabilidad continua**

El riesgo muta: la evaluación es un proceso vivo, no una autopsia final.

Próximo paso: Taller 9 · análisis de riesgos del sistema del cliente y defensa ante el comité.

LECTURAS RECOMENDADAS

ISO 31000 — Gestión del riesgo: principios y directrices

ISO/IEC/IEEE 42010 — Descripción de arquitectura (reemplaza a IEEE 1471)

ATAM — Software Engineering Institute, Carnegie Mellon

Taxonomía de riesgos del SEI

Brown, S. — Risk Storming · riskstorming.com

Open FAIR — The Open Group